DOCUMENTO

Encargo para una sesión local · NIST CSF 2.0 / Cyber AI Profile, perfiles del AI RMF e ISO/IEC 42001 en SEVEN-G

Documento de trabajo (no publicable). 25-09-2026. Lo prepara una sesión en la nube, sin PowerShell ni acceso a nist.gov, para que lo ejecute una sesión en el equipo del autor, con pwsh, Edge y PowerPoint.

Fernando García Varela

EN ESTE DOCUMENTO

00 Antes de empezar

01 Decisiones del autor

02 Reglas que no se pueden saltar en este encargo

03 Entrega 1 · Verificación de fuentes y mapeo (solo documental)

04 Entrega 2 · Perfiles actual y objetivo con la escala de SEVEN-G

05 Entrega 3 · Plantillas P72, P73 y P74

06 Entrega 4 (solo si el autor la confirma) · T15, T01 y T17

07 Entrega 5 (solo si el autor la confirma) · Contenido «Defend» en el 35

08 Comprobación automática nueva (recomendada)

09 Cierre de cada entrega

Cómo usarlo. En la sesión local, pegar:

> Lee `SEVEN-G/mds/es/_trabajo/20260925_Encargo_sesion_local_NIST_CSF_AI_RMF_42001.md` y ejecútalo por entregas, con las reglas de `CLAUDE.md`. Cada entrega termina con `verificar_coherencia.ps1` en verde, y después commit y push a `main`.

00

Antes de empezar

1. **Traer la rama de la evaluación.** El análisis vive en la rama `claude/gracious-brown-rapq4o`. Hay que integrarla en `main` o, si ya se integró, seguir desde `main`: `git fetch origin && git checkout main && git pull && git merge --no-ff origin/claude/gracious-brown-rapq4o` La rama contiene este fichero, la evaluación y un pendiente nuevo en `CLAUDE.md`.
2. Leer, en este orden:
   - `CLAUDE.md` y `.claude/seveng_decisiones.md` (la última decisión es **D109**; las nuevas empiezan en **D110**);
   - `SEVEN-G/mds/es/_trabajo/20260925_Evaluacion_NIST_CSF_Cyber_AI_Profile_AI_RMF_SEVEN-G.md`, que tiene el análisis, el veredicto y el porqué de cada cambio;
   - `_trabajo/20260916_Especificacion_comun_biblioteca_SEVEN-G.md` (§5 códigos, §6.1 lista de plantillas, §7 estructura de cada plantilla) y `_trabajo/20260916_Ajustes_de_coherencia_SEVEN-G.md` (R1–R15);

- `SEVEN-G/build/guia_traduccion_en.md`, para el glosario obligatorio EN;
- los documentos que se tocan: 34 (§1.4, §4, §5, §9, §10), 35 (§6, §7, §9, §10), 11 (§2.2, §7), 01 §13 y 02.

3. Comprobar que el punto de partida está en verde: `pwsh -File SEVEN-G/build/verificar_coherencia.ps1` debe salir con código 0. Si no sale en verde, se arregla eso primero y aparte.

01

Decisiones del autor

La evaluación deja cuatro decisiones abiertas. Si el autor no ha dicho otra cosa, **se aplican las recomendaciones** (regla de `CLAUDE.md`: trabajar con las recomendaciones propias), marcadas «a validar» en el registro de decisiones:

#	Decisión	Por defecto (recomendado)
a	Escala de los perfiles	**Escala 0–5 del documento 11** (D20), con una tabla de equivalencia a los *tiers* del CSF: 0–1 → Tier 1; 2 → Tier 2; 3 → Tier 3; 4–5 → Tier 4. **No** se crea una escala 1–4 capturable aparte.
b	Alcance	Entregas 1 a 3 (mapeo, perfiles y plantillas). La entrega 4 (herramienta) y la 5 (contenido «Defend») solo si el autor las confirma.
c	Cyber AI Profile	Se cita con el estado que tenga, verificado en nist.gov. Si sigue en borrador, se marca «Borrador» y **nunca** fundamenta un criterio de *gate*.
d	Declaración de aplicabilidad de 42001	Sí, como plantilla P74. Identifica los controles del anexo A solo por su código y los parafrasea en términos propios; lleva la advertencia de cotejarla con el texto adquirido de la norma (34 §4.2) y de que SEVEN-G no certifica (D25, 38 §12).

02

Reglas que no se pueden saltar en este encargo

- **D12 / D32:** cada cambio se hace en ES y EN en la misma entrega, con la misma estructura.
- **D41:** ninguna referencia sin verificar con el navegador (iso.org y nist.gov bloquean los clientes automáticos: usar Edge). Cada fuente nueva entra en `SEVEN-G/build/referencias/g5_normas_marcos.json` con el mismo formato que `NIST-AIRMF`: `id`, `tipo`, títulos ES/EN, `emisor`, `fecha`, URLs, `patrones_es/en`, `estado`, `comprobacion` fechada, `documentos`. Después se ejecuta `pwsh -File SEVEN-G/build/verificar_referencias.ps1`.
- **D30:** cada concepto o plantilla nueva lleva su «Por qué importa» (EN: «Why it matters»).

- **D40:** no escribir «previsto», «en construcción» ni «por construir» referido a SEVEN-G.
- **D53:** nada se rompe hacia atrás. Los esquemas y herramientas solo ganan campos opcionales.
- **Derechos de las normas (93 §4: las normas citadas tienen sus propios titulares):** no reproducir el texto de ISO/IEC 42001 . Del AI RMF y del CSF, usar identificadores (GOVERN 1.1, PR.DS-01…) con descripción en términos propios, como ya hace el 34.
- **D109:** los `classDef` de los diagramas Mermaid nuevos no pueden llamarse como una clase de `estilo.css` .
- Recuadro «Lo esencial» (D75): los documentos que se tocan ya lo tienen. No cambiar su nivel sin tocar también la matriz del 94 §6.

03

Entrega 1 · Verificación de fuentes y mapeo (solo documental)

Fuentes que hay que verificar con Edge y dar de alta en el registro de referencias:

id propuesto	Qué es	Qué hay que comprobar
`NIST-CSF-2`	NIST Cybersecurity Framework 2.0 (NIST CSWP 29, 26-02-2024)	URL oficial (nist.gov/cyberframework o la DOI 10.6028/NIST.CSWP.29), definición de *tiers* y perfiles
`NIST-IR-8596`	Cyber AI Profile	**Estado actual**: preliminar de 16-12-2025 (iprd) o borrador público inicial (ipd, 2026) o final. URL de la versión vigente; áreas Secure / Defend / Thwart
`NIST-AIRMF-42001-XW`	Correspondencia AI RMF ↔ ISO/IEC 42001 en el AIRC de NIST (`airc.nist.gov` , página de *crosswalks*)	Quién la firma (¿NIST o un tercero alojado?), que se hizo sobre el FDIS, fecha
(existente) `ISO-42001`	Está en estado `corregir`	Aprovechar para cerrar la corrección del 34 §4 descrita en su campo `correccion`

Cambios en los documentos (ES y EN):

1. **34 · Mapeo regulatorio**
   - §1 (objeto y alcance): añadir el CSF 2.0 y el Cyber AI Profile a la lista de lo que se mapea.
   - Nueva sección **«NIST CSF 2.0 y Cyber AI Profile»**. Recomiendo §5.3 dentro del bloque NIST, para no renumerar el resto. Contenido:
     - qué son, qué estado tiene cada uno y que son voluntarios;
     - **advertencia sobre los *tiers***: describen el rigor de toda la organización, no la madurez de cada subcategoría, y el AI RMF no tiene *tiers*;

        - tabla con el formato del 34 (Obligación / requisito · Artículo o cláusula · A quién aplica · Fase o etapa SEVEN-G · Rol responsable · Evidencia · Herramienta) para las seis funciones del CSF: GV, ID, PR, DE, RS, RC;
        - tabla del Cyber AI Profile por áreas: **Secure** → 35 §3–§8, SEG-01…14, AG-; **Thwart** → 35 §9, SEG-15…19; **Defend** → «Sin cobertura específica en la versión 0.x; se trata como caso de uso con los controles de autonomía del 35 §5» (o lo que diga la entrega 5).
    - §9 (matriz resumen): columna o filas para el CSF.
    - §10 (fuentes) y §1.4: añadir las fuentes con su estado de verificación.
    - Control de versiones del 34: nueva fila.
2. **35 · Seguridad de IA y agentes**
    - §1.2 (referencias): CSF 2.0 y Cyber AI Profile.
    - §6 y §7: **columna «Función CSF»** en los catálogos SEG y AG, con la función principal de cada control (por ejemplo: SEG-01 → ID; SEG-12 → DE; SEG-14 → RS; SEG-20 → GV/PR).
    - Control de versiones.
3. **01 §13**: fila «NIST CSF 2.0 y Cyber AI Profile» en la tabla de referencias.
4. **02 · Glosario**: «NIST CSF», «Cyber AI Profile», «*tier* (CSF)», «perfil actual», «perfil objetivo». En `guia_traduccion_en.md` : *tier* no se traduce; perfil actual → *current profile*; perfil objetivo → *target profile*.
5. **Decisión D110** en `.claude/seveng_decisiones.md` : mapeo de CSF 2.0 y Cyber AI Profile, estado de las fuentes y regla de que un borrador no fundamenta criterios de *gate*.

Regenerar y verificar: `pwsh -File SEVEN-G/build/build.ps1` ; revisar el HTML y el PDF del 34 y del 35 (tablas anchas: comprobar que caben en el PDF con `pdf_a_png.ps1`); `verificar_coherencia.ps1` debe salir en verde. Luego commit y push.

04

Entrega 2 · Perfiles actual y objetivo con la escala de SEVEN-G

1. **11 · Modelo de madurez**
    - §2.2: tabla de **equivalencia 0–5 ↔ *tiers*** (la de la evaluación §2), con la advertencia de que es orientativa (los *tiers* no exigen los dos trimestres del nivel 4 ni el ciclo C5 del nivel 5).
    - §7: nuevo vínculo **«Con los perfiles NIST (AI RMF y CSF)»**. El nivel de cada subcategoría se **deriva de las preguntas del cuestionario** (D1…D7) cuando existen, y solo se pregunta aparte lo que no cubren. Una evaluación, dos lecturas. Sin evidencia verificada, no hay nivel (11 §1.2).
    - Control de versiones.

2. **34 §5.1**: añadir, como anexo del 34 o como tabla nueva, el **desglose por subcategoría del AI RMF** (GOVERN 1.1 … MANAGE 4.3). Por subcategoría: identificador, descripción breve en términos propios, dónde lo cubre SEVEN-G (documento §, P, T) y qué pregunta del documento 11 da su nivel (D1.xx…D7.xx), o «pregunta propia» si no hay ninguna. Hay que **comprobar contra la fuente oficial el número exacto de subcategorías** y no escribirlo de memoria.
3. Lo mismo para las subcategorías del CSF 2.0 relevantes para la IA según el Cyber AI Profile. Si el perfil es borrador, se indica que la selección es provisional.
4. **Decisión D111**: perfiles actual y objetivo en la escala 0–5 con equivalencia a los *tiers*; no hay escala 1–4 aparte. Estado: «a validar por el autor».

Regenerar y verificar, como en la entrega 1.

05

Entrega 3 · Plantillas P72, P73 y P74

Estructura de la especificación común §7, con «Por qué importa», aviso legal, directiva `<!-- esencial: … -->` y control de versiones. En ES y EN, en `SEVEN-G/mds/<idioma>/plantillas/`:

Código	Contenido mínimo
Perfil de seguridad de IA (CSF 2.0 / Cyber AI Profile) (P72)	Perímetro y fecha de corte; por subcategoría seleccionada: nivel actual (0–5) con su evidencia, nivel objetivo y quién lo fija (C2), brecha, acción, responsable y fecha; *tier* equivalente calculado; resumen por función CSF y por área (Secure / Defend / Thwart)
Perfil de gobierno de IA (NIST AI RMF) (P73)	Lo mismo por subcategoría del AI RMF, agrupado por GOVERN / MAP / MEASURE / MANAGE, con las características de fiabilidad (sesgo, transparencia, rendición de cuentas, supervisión humana) visibles; enlace a P34 (informe de madurez) para no duplicar evidencias
Declaración de aplicabilidad de ISO/IEC 42001 (P74)	Por control del anexo A (solo el código y una paráfrasis): aplicable sí/no, justificación, dónde lo cubre SEVEN-G, evidencia, estado de implantación y subcategoría del AI RMF correspondiente. Advertencias: cotejar con el texto adquirido de la norma; SEVEN-G no certifica (D25); la certificación la emite una entidad acreditada (38 §12)

Hay que dar de alta las plantillas nuevas en todos los sitios que hoy dicen «71» o «P01–P71» (lista obtenida buscando «P71», «71 plantillas» y «71 templates», ES y EN):

- `README.md` (línea «plantillas P01–P71»);
- `index.html` y `en/index.html` (cifra `<b>71</b>`, escrita a mano);
- `SEVEN-G/build/entrada/es|en/index.html` (cifra 71, escrita a mano; D91: la copia en `html/` la hace `build.ps1`);
- 00 §10 (fila «H · Plantillas»), 02 (§ del bloque H y la fila de códigos «P01–P71»), 03 (catálogo: «P32–P71»), 04 §2.3 si se quiere un hito, 90, 93 (tabla de licencias «P01–P71»), 94 §7.2 (**añadir la fila de**

nivel de P72–P74; recomiendo «Condicional»: solo si la compañía usa marcos NIST o aspira a 42001), módulo M01 del curso;

- especificación común §6.1 (lista de plantillas) y §5 (sin códigos nuevos, salvo que se decida uno para los perfiles);
- documentos que las usan: 34 (§4.2 → P74; §5 → P73; nueva sección CSF → P72), 35 §10 o §12 → P72, 11 §10 → P73, 38 §12 → P74;
- `SEVEN-G/build/curso_pptx.ps1` solo si algún curso debe mencionarlas (no es obligatorio).

`verificar_coherencia.ps1` (22) avisa si las cifras escritas a mano no coinciden con la biblioteca. Los `.docx` los genera `build.ps1` (D67), y la sección correspondiente comprueba que existen y que están al día.

Decisión D112: plantillas P72–P74. P74 queda «a revisar por asesoría jurídica o por un auditor de 42001 antes de ofrecerla».

Regenerar dos veces (primera generación de documentos nuevos: así cada idioma enlaza el PDF del otro), revisar visualmente una plantilla en PDF y en Word, pasar `verificar_coherencia.ps1`, y hacer commit y push.

06

Entrega 4 (solo si el autor la confirma) · T15, T01 y T17

- **T15** (`SEVEN-G/herramientas/T15_diagnostico_madurez/`): dos vistas nuevas, «Perfil de seguridad (CSF / Cyber AI)» y «Perfil de gobierno (AI RMF)». Nivel actual derivado de las respuestas del cuestionario del 11 cuando la subcategoría tiene pregunta asociada; nivel objetivo editable; brecha; *tier* equivalente; exportación CSV. Las correspondencias van en un JSON nuevo (por ejemplo, `perfiles_nist.json`) generado o comprobado contra las tablas del 34, igual que `catalogo_riesgos.json` contra el 33 (D106). La aplicación se edita en `_fuentes/` y se regenera con `build_madurez.ps1`, nunca a mano.
- **T01, esquema 0.7** (solo campos opcionales, D53): `madurez[].perfiles` con un resumen por función, sin respuestas.
- **T17**: el conector en **Python y en JS a la vez** (`t01_a_panel.py` y `t01_a_panel.js`; la sección 19b falla si divergen); la brecha, en la tarjeta de madurez. Regenerar el panel de ejemplo (`uv run python t01_a_panel.py`) y T01.
- Actualizar `herramientas/mapa_datos.json`, el 03 §4 y §4.1 (ES/EN), los README de T15, T01 y T17 (ES/EN) y la prueba de humo (7) de `verificar_coherencia.ps1`.
- Si cambian las capturas de datos de demostración, recapturar las imágenes indicadas en los pendientes de `CLAUDE.md`.

- **Decisión D113.**

07

Entrega 5 (solo si el autor la confirma) · Contenido «Defend» en el 35

Nueva sección del 35 (ES/EN) sobre **usar la IA en la ciberdefensa de la compañía**: detección y respuesta asistidas; nivel de autonomía A0–A3 de la respuesta automatizada; supervisión humana antes de acciones de contención con efecto en producción; falsos positivos y negativos como indicadores; dependencia del proveedor; pruebas adversarias del propio sistema defensivo. Añadir controles con código nuevo (SEG-21 en adelante) o reutilizar AG-. Si aparecen riesgos tipo nuevos en el 33 §9, **darlos de alta en** `catalogo_riesgos.json` (pendiente D106: `build_registro.ps1` falla si el 33 y el catálogo no coinciden) y regenerar `registro.html`. Si procede, añadir la fila del caso de uso en la esfera del documento 10 y revisar SPHERES (D42). **Decisión D114.**

08

Comprobación automática nueva (recomendada)

Añadir a `verificar_coherencia.ps1` una **sección 23** que compruebe:

1. que el 34 (ES/EN) contiene la sección del CSF y el Cyber AI Profile, y que cada función GV/ID/PR/DE/RS/RC aparece en su tabla;
2. que los catálogos SEG y AG del 35 (ES/EN) tienen la columna «Función CSF» sin celdas vacías;
3. que la tabla de equivalencia 0–5 ↔ *tiers* del 11 es idéntica en ES y EN;
4. que P72–P74 existen en ES/EN, en HTML, PDF y `.docx`, y que la matriz del 94 les da nivel;
5. que ninguna página publicada presenta el Cyber AI Profile como definitivo mientras su entrada del registro de referencias no diga que lo es.

09

Cierre de cada entrega

1. `pwsh -File SEVEN-G/build/build.ps1` (dos veces si hay documentos o plantillas nuevos).
2. Revisión visual: `servidor.ps1` y `http://localhost:8765/SEVEN-G/html/es/`; capturas del PDF con `powershell.exe -File SEVEN-G/build/pdf_a_png.ps1` (rutas de salida cortas).

3. `pwsh -File SEVEN-G/build/verificar_coherencia.ps1`, que debe salir con código 0. Si falla, se corrige o se explica, y **no se publica** (D52).
4. Registro de decisiones al día. En `CLAUDE.md`, sustituir el pendiente del 25-09-2026 por lo que quede. En la evaluación (`20260925_Evaluacion_…md`), marcar qué entregas están hechas. Estado en el plan documental (`_trabajo/20260916_Analisis_estado_y_huecos_SEVEN-G.md`) y en el catálogo del 03 si afecta a herramientas.
5. Commit con un mensaje descriptivo y push a `main`.

Fuentes externas citadas

Enlaces a la fuente oficial o primaria, comprobados antes de publicar. Verifique siempre la versión vigente en la fecha de uso.

Perfil del marco de ciberseguridad para la inteligencia artificial (Cyber AI Profile): perfil comunitario del NIST, NIST IR 8596 (borrador preliminar inicial) · https://csrc.nist.gov/pubs/ir/8596/iprd · National Institute of Standards and Technology (NIST), NCCoE · 16-12-2025

ISO/IEC 42001:2023 Tecnología de la información — Inteligencia artificial — Sistema de gestión · https://www.iso.org/standard/42001 · ISO/IEC (JTC 1/SC 42) · 18-12-2023

Marco de ciberseguridad del NIST, versión 2.0 (The NIST Cybersecurity Framework (CSF) 2.0), NIST CSWP 29 · https://doi.org/10.6028/NIST.CSWP.29.spa · National Institute of Standards and Technology (NIST), Departamento de Comercio de EE. UU. · 26-02-2024

Marco de gestión de riesgos de inteligencia artificial del NIST (AI RMF 1.0), NIST AI 100-1 · https://www.nist.gov/publications/artificial-intelligence-risk-management-framework-ai-rmf-10 · National Institute of Standards and Technology (NIST), Departamento de Comercio de EE. UU. · 26-01-2023